

Building security and autoremediation in AWS

(and beyond)

AWS Meetup Estonia 🇪🇪 vol.3
a meetup by Glassity and Revolgy



\$ aws sts get-caller-identity --profile unicrons.cloud

Samuel

Cloud Security Engineer @ *flywire*

  sbldevnet



Andoni

Cloud Security Engineer @ freelance

  andoniaf



\$ aws sts get-ca

Samuel

Cloud Security Engineer @ [flywire](#)

[in](#) [github](#) sbldevnet



ons.cloud

Andoni

Cloud Security Engineer @ freelance

[in](#) [github](#) andoniaf



The problem

✓ Deploy CSPM

Cloud Security Posture Management

Due: Jun 3

Assigned to: Larry Lease

Priority: High |



The problem

- Lack of customization
- Lack of context (enrichment and exceptions)
- Alert fatigue
- Remediation

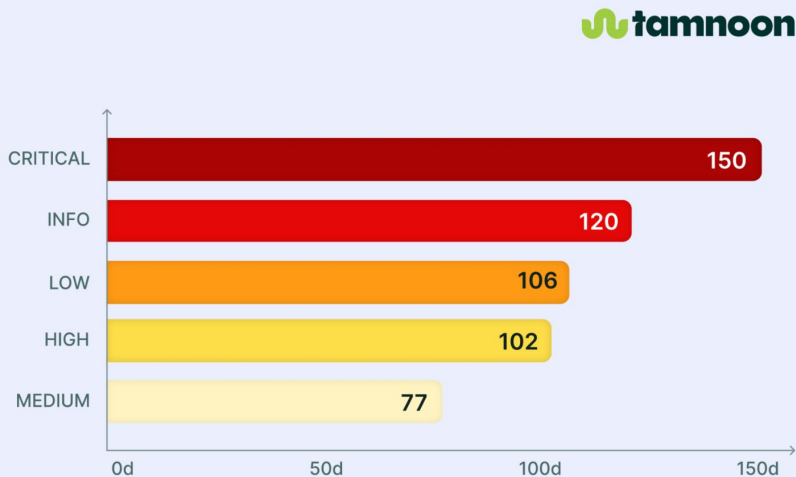


The problem

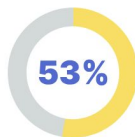
- Lack of customization
- Lack of context (enrichment and exceptions)
- Alert fatigue
- **Remediation**



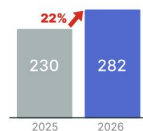
Average Days to Close, by Source-CNAPP Severity Tag (2026)



KEY CLOUD SECURITY TRENDS



of all CNAPP-detected alerts remain OPEN so far in 2026.



22% increase in Vulnerability Management MTTR YoY, from 230 to 282 days.



of all alerts come from the same 8 misconfigurations seen last year.



150 days

was the average exposure window for Critical alerts before remediation ships.



6.3%

of open alerts touch a Crown Jewel asset.

13%*



of all alerts were classified as critical in 2026, up from 1.4% in 2025.



“Over half of the vulnerabilities addressed by organizations tend to **recur within a month** of remediation.”



<https://cloudsecurityalliance.org/artifacts/the-state-of-security-remediation-survey-report>



“Thirty-seven percent describe their automation as largely alert-focused, identifying potential issues but leaving remediation to manual processes.

Only 11% report autonomous remediation capabilities that can act without human intervention.”



The problem

Auto Remediation Is Hard

- Context is complex
- Alert fatigue
- Tool sprawl
- Risk of breaking production





Auto Remediation: The Rules



Farris's Three Laws of Cloud Security Auto Remediation

A bot must never harm stateful data or allow stateful data to come to harm.



<https://www.chrisfarris.com/post/three-laws/>



Farris's Three Laws of Cloud Security Auto Remediation

**A bot must act with utmost haste
so functionality doesn't become
dependent on a misconfiguration.**



<https://www.chrisfarris.com/post/three-laws/>



Farris's Three Laws of Cloud Security Auto Remediation

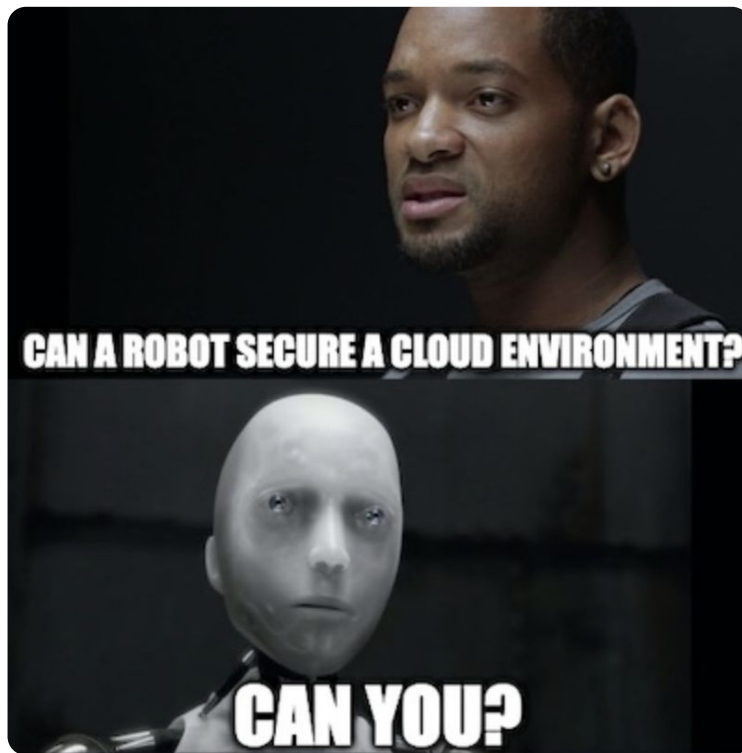
**A bot must announce its existence
and tell a carbon-based life form
what it did and why.**



<https://www.chrisfarris.com/post/three-laws/>



Farris's Three Laws of Cloud Security Auto Remediation



(Stolen meme)



<https://www.chrisfarris.com/post/three-laws/>



Build VS Buy



Different Paths to Auto Remediation

Native Auto Remediation

- Easy to start
- Harder to customize

3rd Party Auto Remediation

- Easy to start (if they support your platforms)
- Limited customization
- \$\$\$

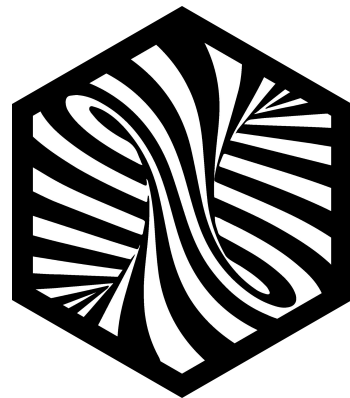
Build Your Own Auto Remediation

- Needs know-how
- Fully customizable

(combine some of them)



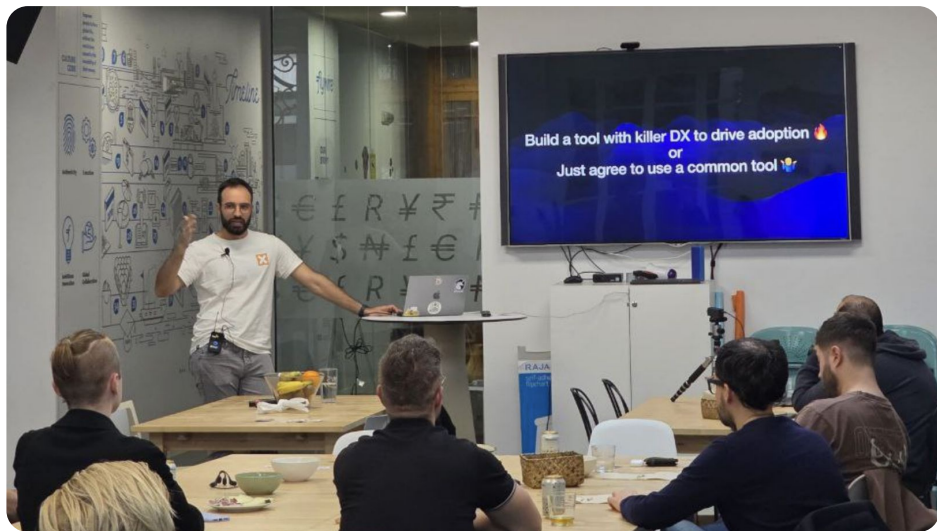
Build + Innersource



“**InnerSource** takes the lessons learned from developing open source software and applies them to the way companies develop software internally.”



innersourcecommons.org



And what about AI?

- Still exploring
- Ensure proper guardrails and constraints
- Human in the loop



What are we building?

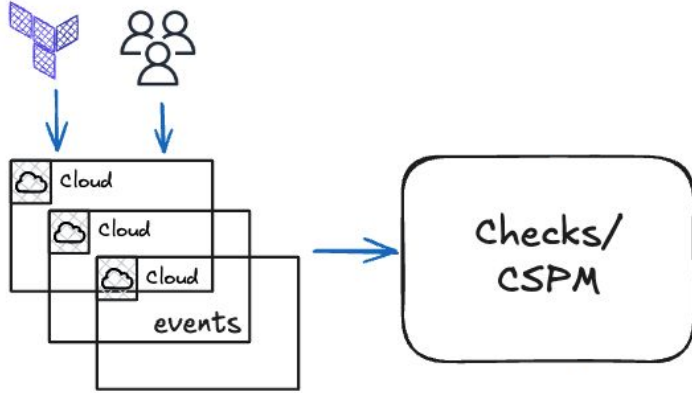


What are we building?

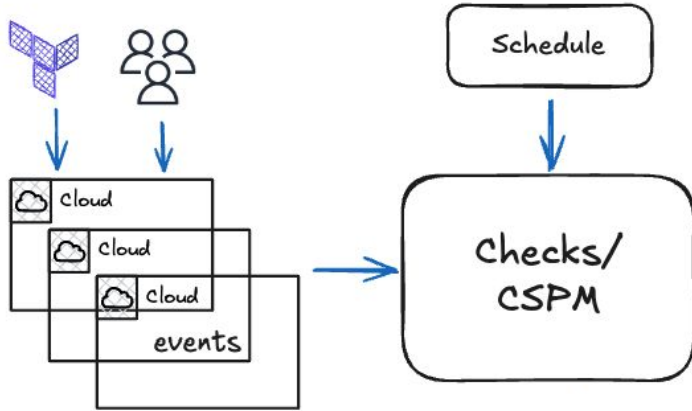
Checks/
CSPM



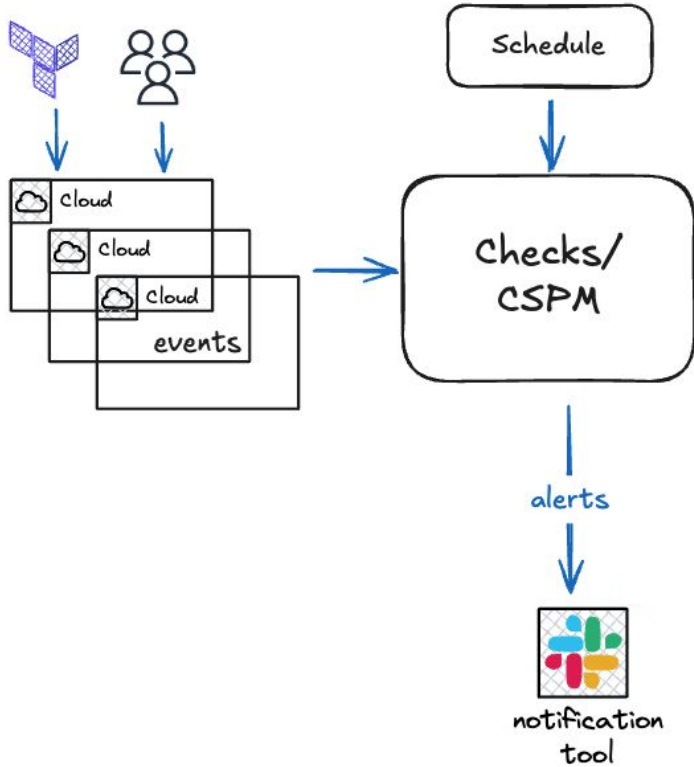
What are we building?



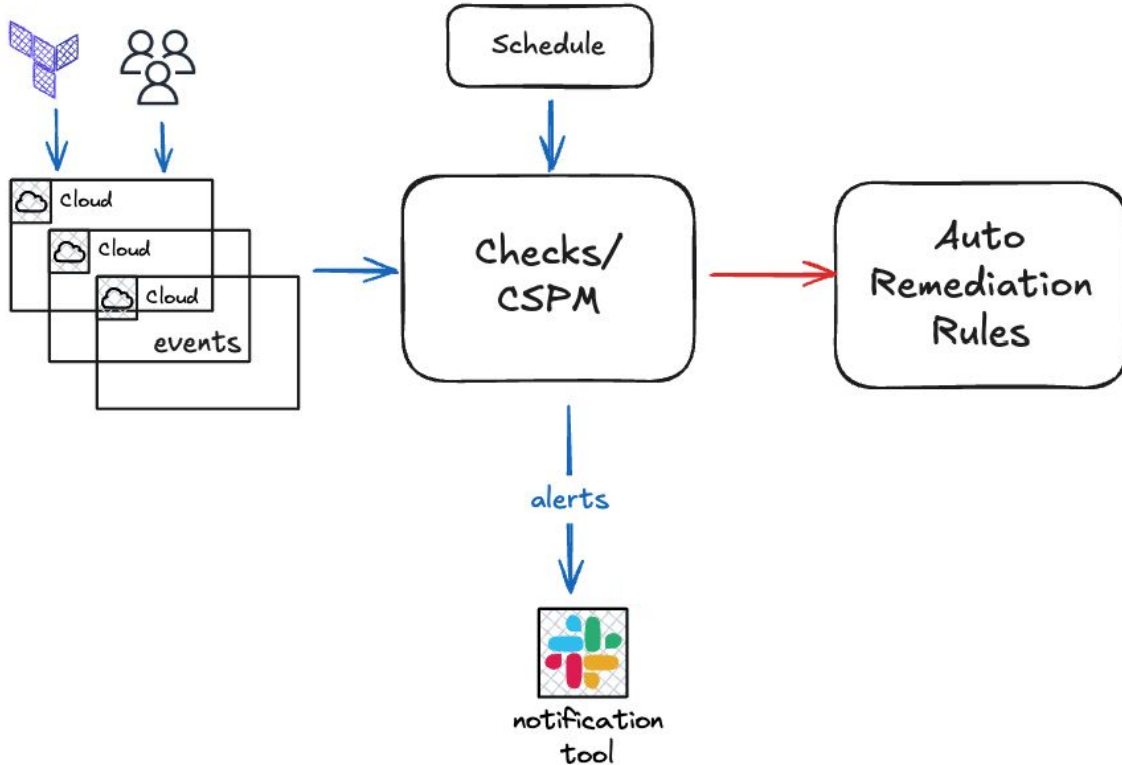
What are we building?



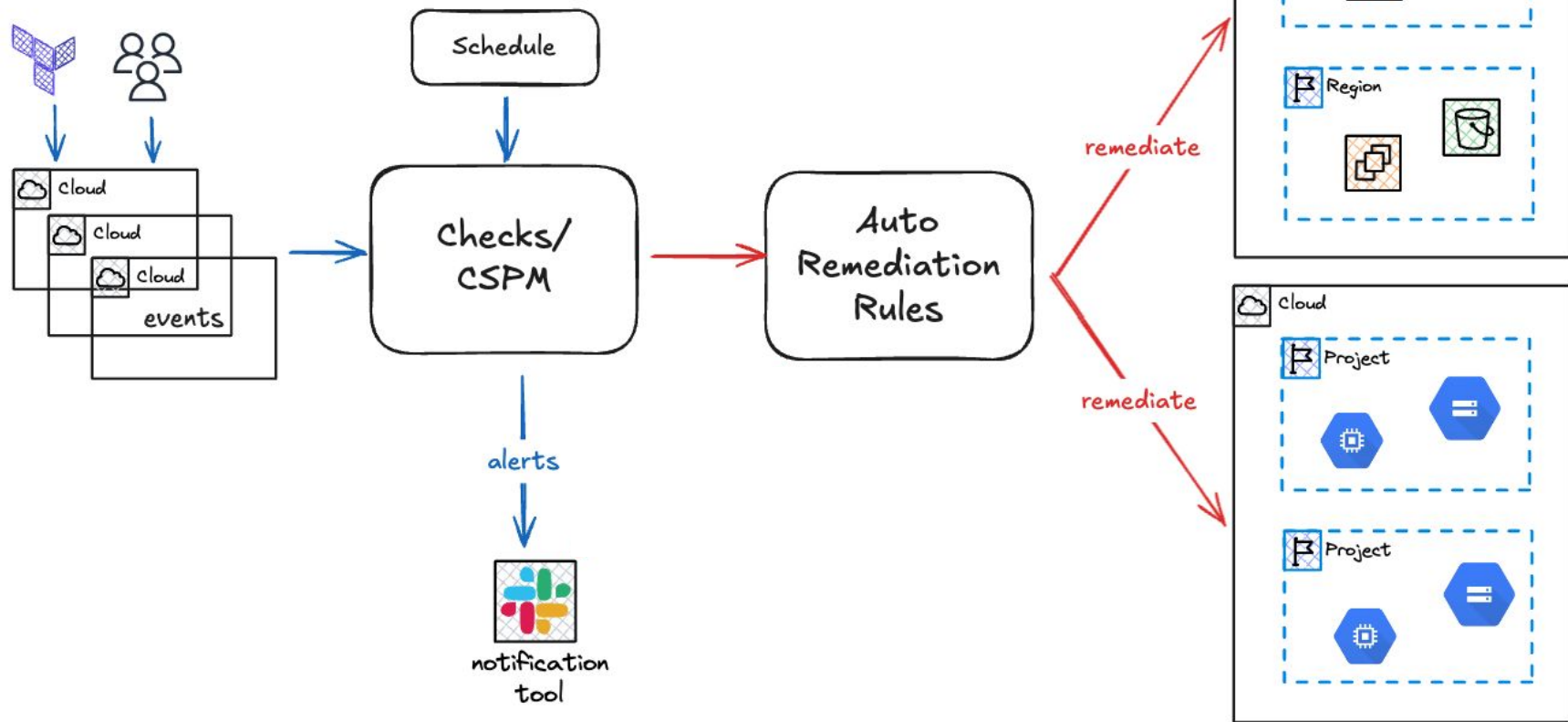
What are we building?



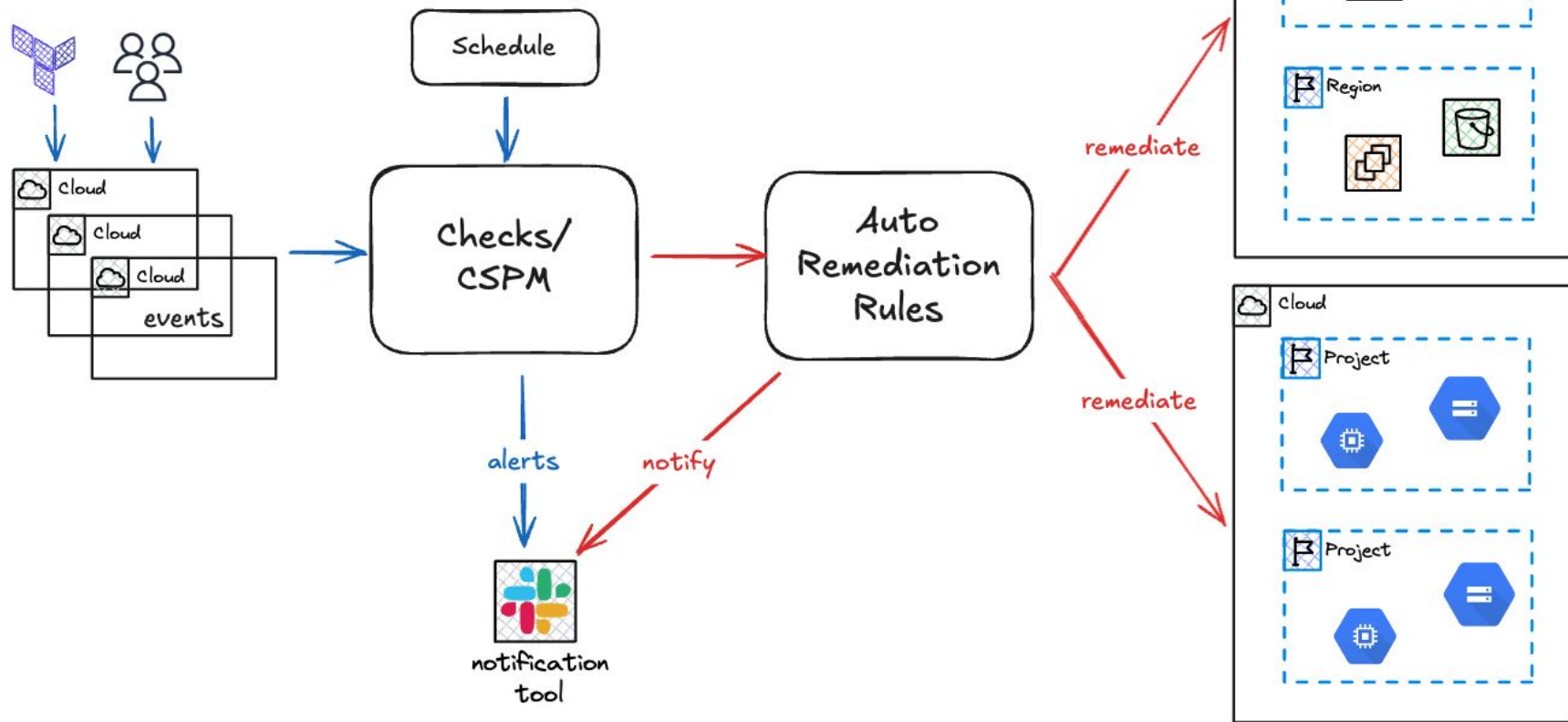
What are we building?



What are we building?



What are we building?



AWS Native Auto Remediation

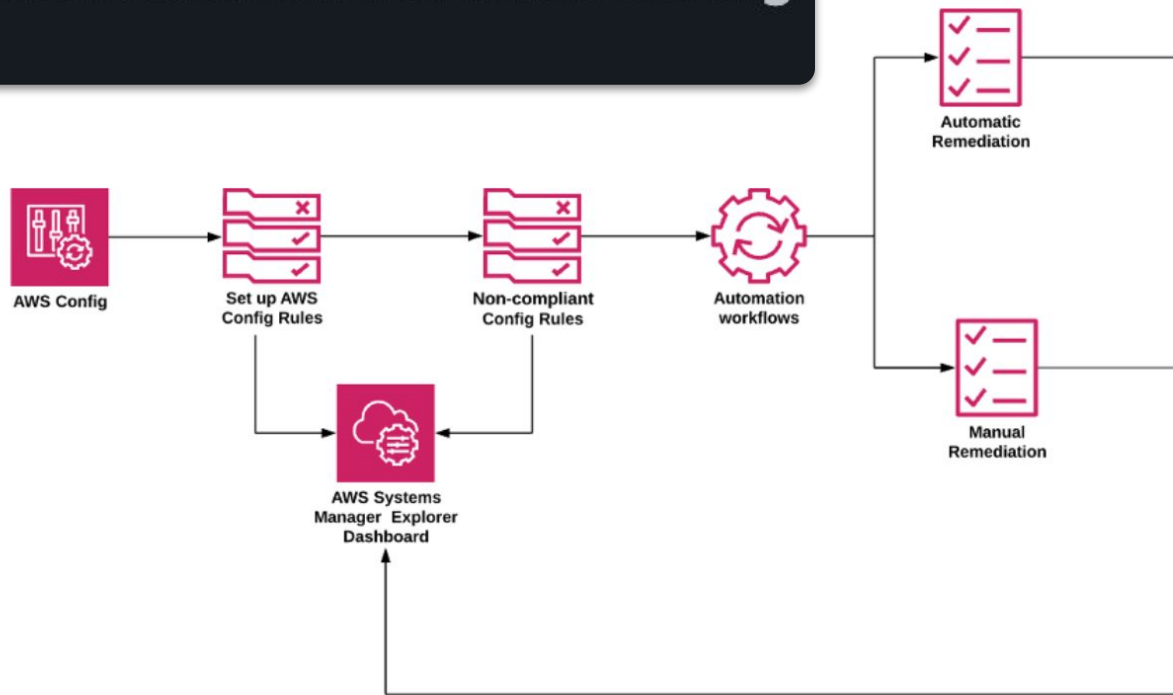
[Documentation](#) > [AWS Config](#) > [Developer Guide](#)

Setting Up Auto Remediation for AWS Config

PDF

RSS

Focus mode



<https://aws.amazon.com/blogs/mt/remediate-noncompliant-aws-config-rules-with-aws-systems-manager-automation-runbooks/>



AWS Native Auto Remediation

[AWS Documentation](#) > [AWS Solutions Library](#) > Automated Security Response

Automated Security Response on AWS

Resolve common security threats and improve your security posture

[Go to guide](#)

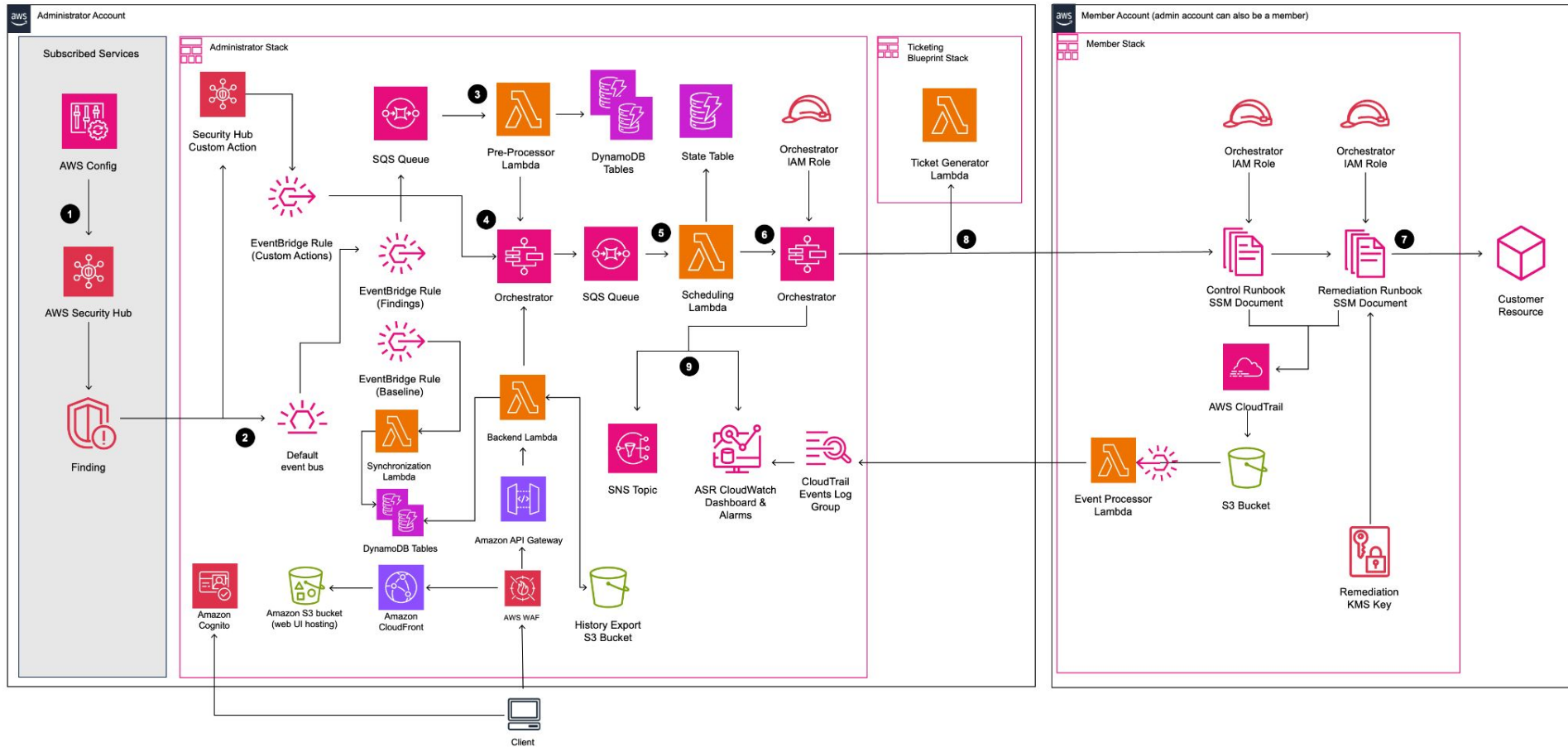
[Deploy now](#)



<https://docs.aws.amazon.com/solutions/automated-security-response-on-aws/>



AWS Native Auto Remediation



AWS Native Auto Remediation

Custom policy [Info](#)

[Pre-populate configuration](#)

Customize your Security Hub configuration policy.

Security Hub [Info](#)

Specify whether Security Hub should be enabled or disabled in this policy.

☒ Enable Security Hub CSPM

Recommended

☐ Disable Security Hub CSPM

Security standards [Info](#)

A standard is a collection of security controls that represent security best practices. Choose the standards to enable. Any standard not selected will be disabled. [Service-managed standards](#) [↗](#) are not managed by policies.

Choose standards to enable

AWS Foundational Security Best Practices v1.0.0 [✕](#)

Controls [Info](#)

Controls are evaluated for compliance during security checks. These control selections will apply to any enabled standard.

☒ Enable all controls

New controls will also be enabled.

☐ Disable specific controls

All other controls will be enabled, including new controls.

☐ Enable specific controls

All other controls will be disabled.

[i](#) You must enable AWS Config resource recording

Security Hub can generate control findings only if you turn on AWS Config resource recording in all accounts and Regions where you use Security Hub. You must enable resource recording separately for resource recording. For more information, see the [AWS Config pricing page](#) [↗](#).

You can turn on resource recording on the [AWS Config console](#), or you can choose Download to deploy an AWS CloudFormation template. For more information, see the [Security Hub user guide](#) [↗](#).

AWS Native Auto Remediation



AWS Native Auto Remediation

AWS Config > Rules > securityhub-cloud-trail-encryption-enabled-56ebf2cb



This rule has been created by securityhub.amazonaws.com

This is a service-linked AWS Config rule, which is a unique type of managed config rule that supports other AWS services to create AWS Config rules in your account. You cannot edit or delete these rules if you are subscribed to AWS services that these rules are linked to.

[Learn more about Service-Linked AWS Config Rules.](#)

securityhub-cloud-trail-encryption-enabled-56ebf2cb

Actions ▲

Manage remediation

Re-evaluate

Delete results

Delete rule

Edit rule

Details

Description

Checks if AWS CloudTrail is configured to use the server side encryption (SSE) AWS Key Management Service (AWS KMS) encryption. The rule is COMPLIANT if the KmsKeyId is defined.



Note

You can only manage remediations for non-service linked AWS Config rules. For more information, see [Service-Linked AWS Rules](#).



<https://docs.aws.amazon.com/config/latest/developerguide/service-linked-awsconfig-rules.html>



The real Implementation



Our Architecture: Context First

2 AWS Organizations

+ 60 AWS Accounts

19 regions in use

**+ 20,000 resources
per account**

3 Cloud Service Providers

**4 different internal
platforms**

Cloudflare

Github

Gitlab

Okta

...

Highly regulated company

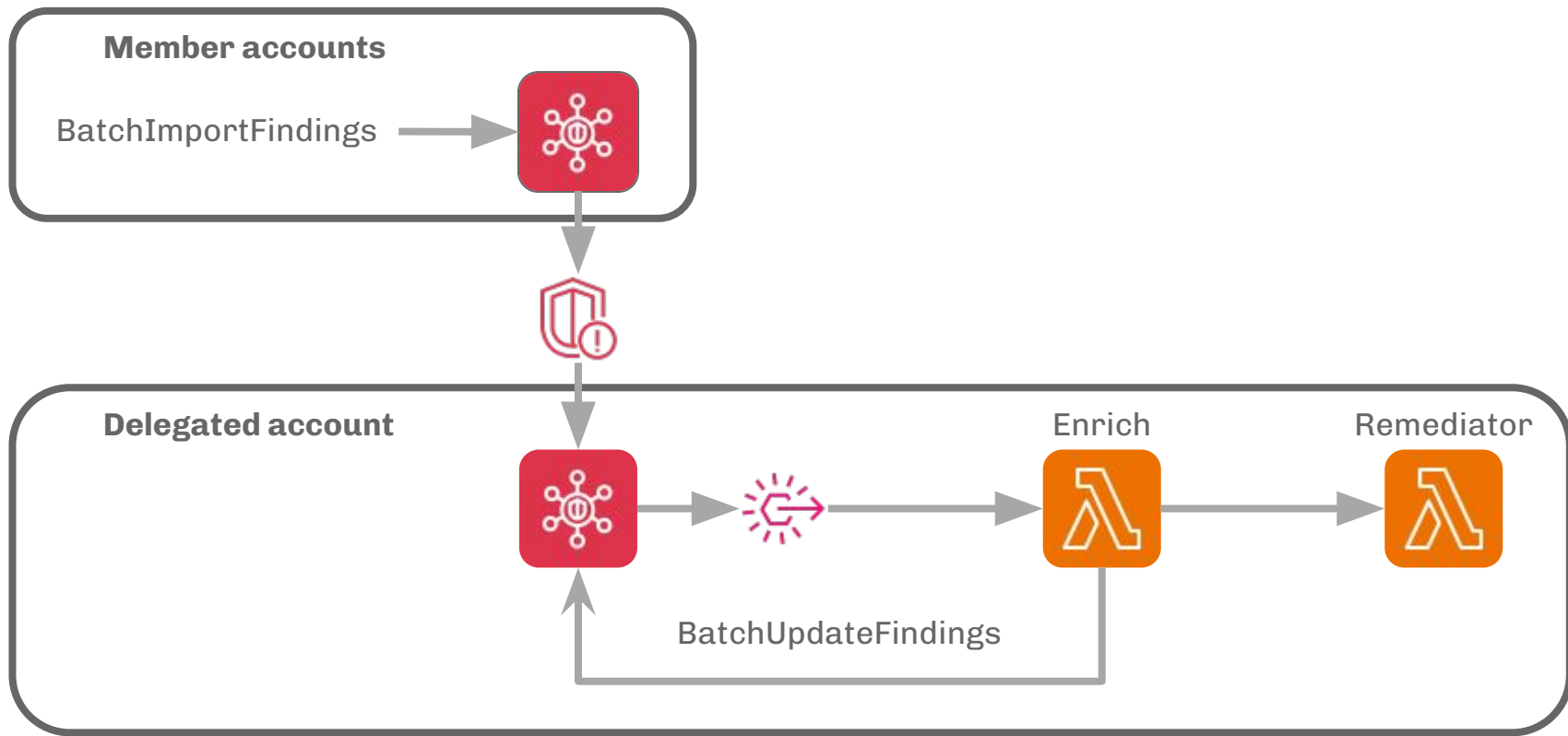
3 People in the team

~ 2000 Controls Processed per day



Key Design Decisions

Trigger

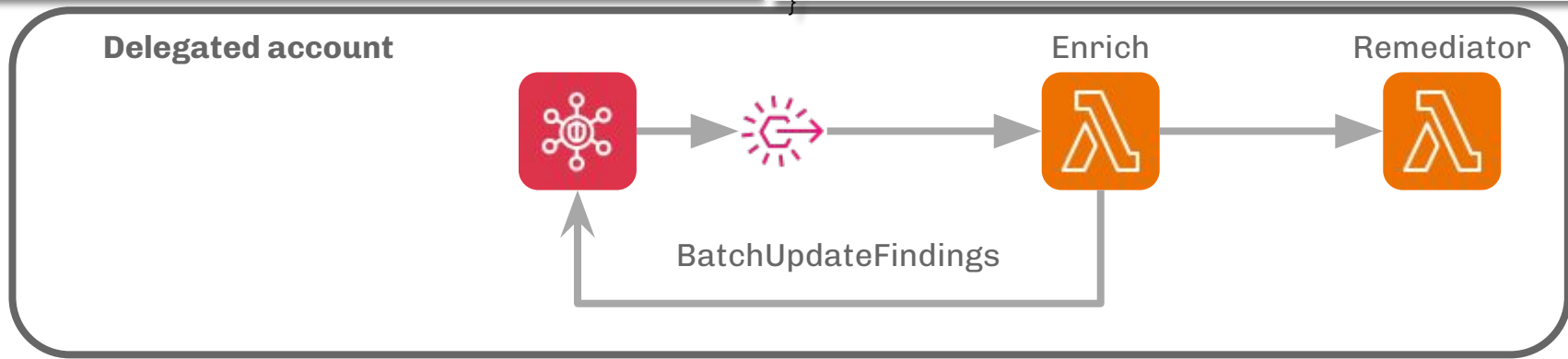


Key Design Decisions

Trigger

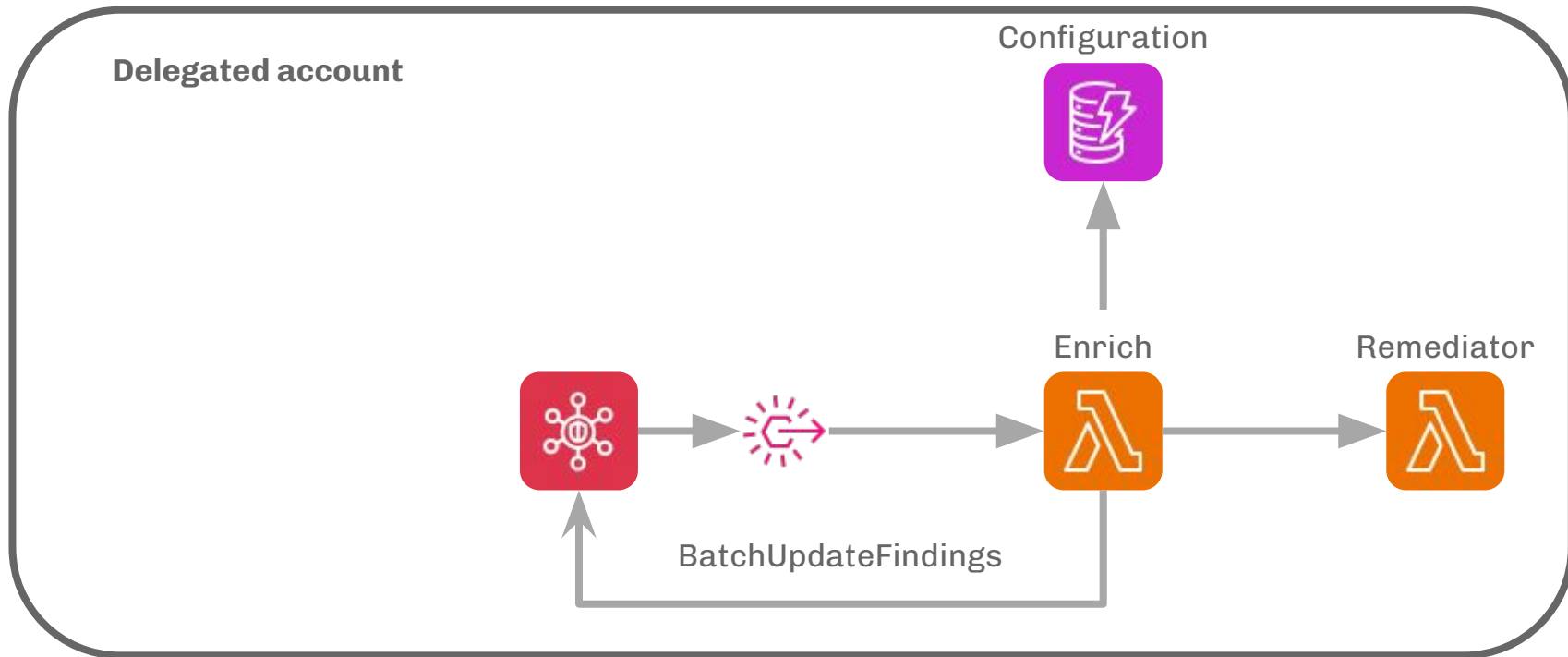
```
{  
  "provider": "aws",  
  "control": "aws_s3_public_bucket",  
  "account": "123456789012",  
  "region": "eu-west-1",  
  "resource": "arn:aws:...",  
  "tags": "{}"  
}
```

```
{  
  "provider": "cloudflare",  
  "control": "cf_zones_min_tls_version",  
  "account":  
    "112233445566778899aabbccdd",  
  "region": "us-east-1",  
  "resource": "domain.com",  
  "tags": "{}"  
}
```



Key Design Decisions

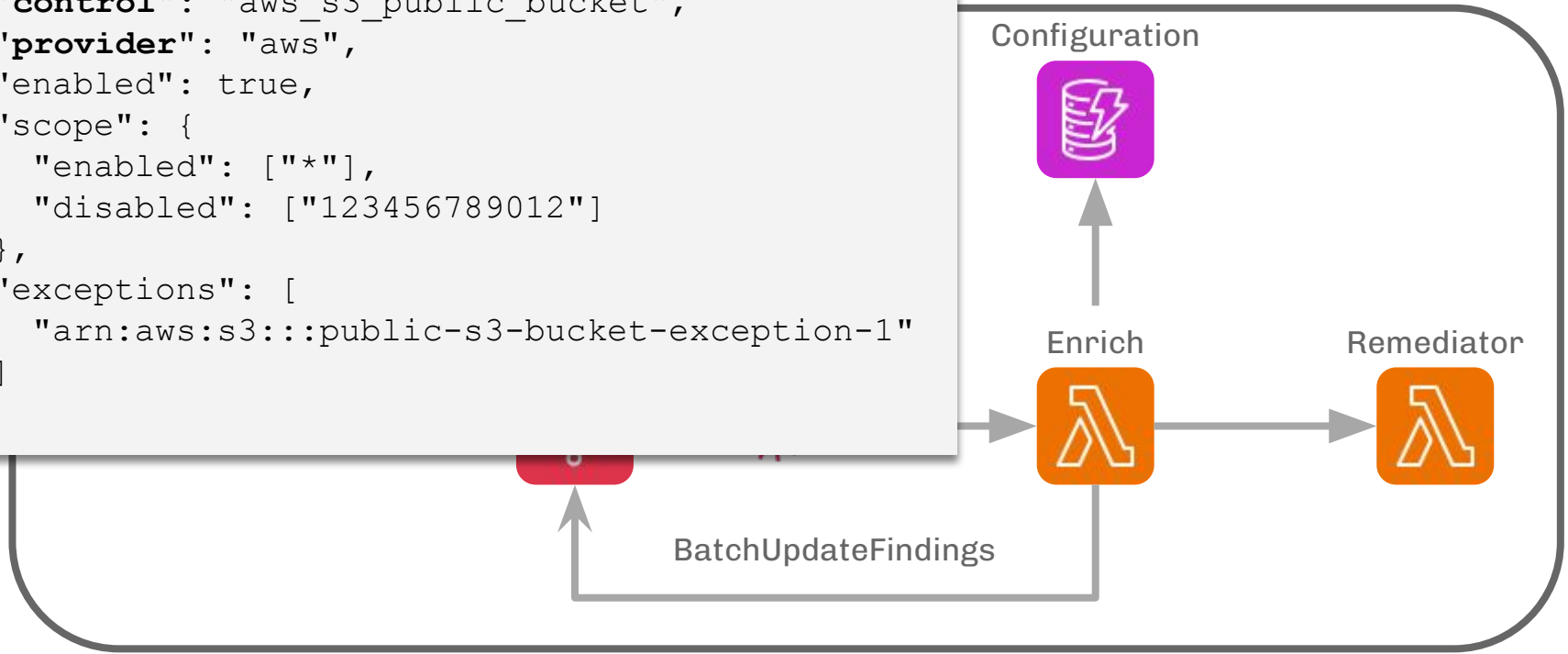
Configuration



Key Design Decisions

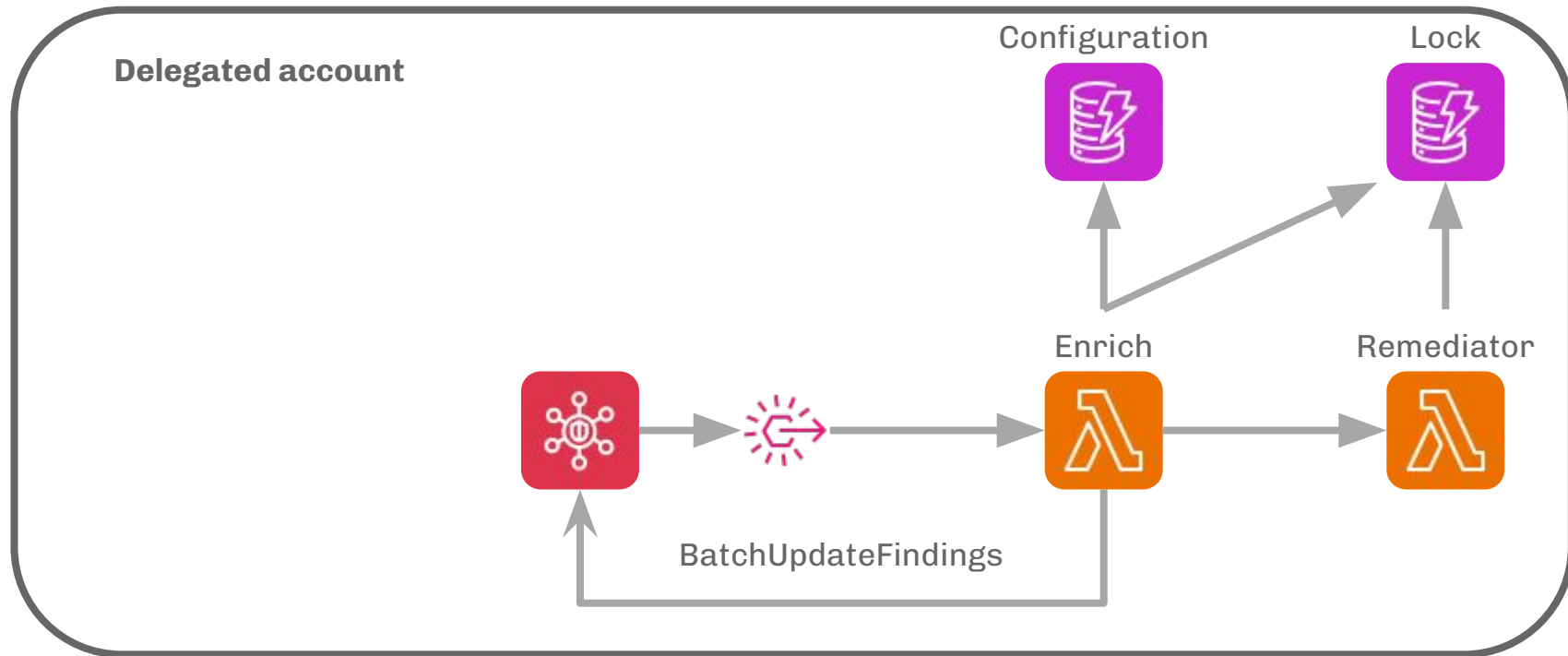
Configuration

```
{  
  "control": "aws_s3_public_bucket",  
  "provider": "aws",  
  "enabled": true,  
  "scope": {  
    "enabled": ["*"],  
    "disabled": ["123456789012"]  
  },  
  "exceptions": [  
    "arn:aws:s3:::public-s3-bucket-exception-1"  
  ]  
}
```



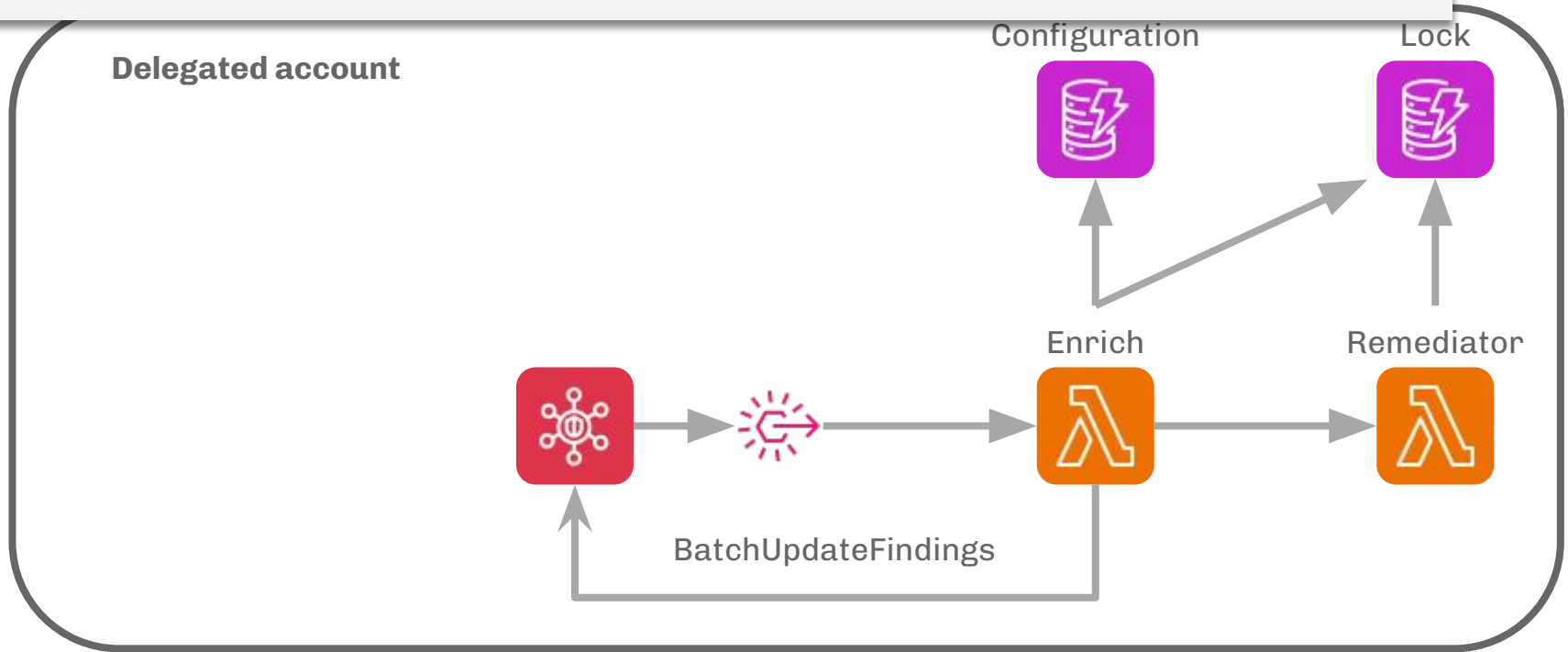
Key Design Decisions

Lock



Key Design Decisions

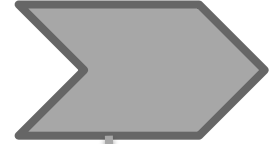
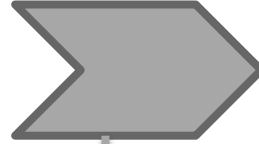
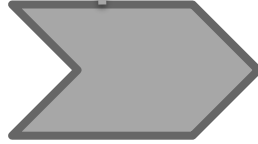
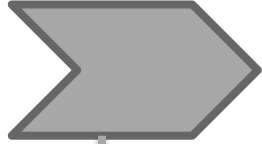
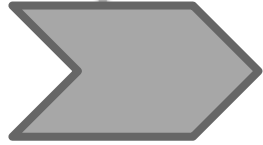
```
{  
  "resource_identifier": "arn:aws:s3:::public-s3-bucket-exception-1",  
  "control": "aws_iam_password_policy",  
  "ttl": 1754899200  
}
```



New Public Bucket
using IaC

Admin change it to
public

Dev triggers a new
CI



Auto Remediation

Auto Remediation

Auto Remediation

Auto
Remediation

Manual
Changes

Auto
Remediation

Auto
Remediation

Manual
Changes

Auto
Remediation

Manual
Changes

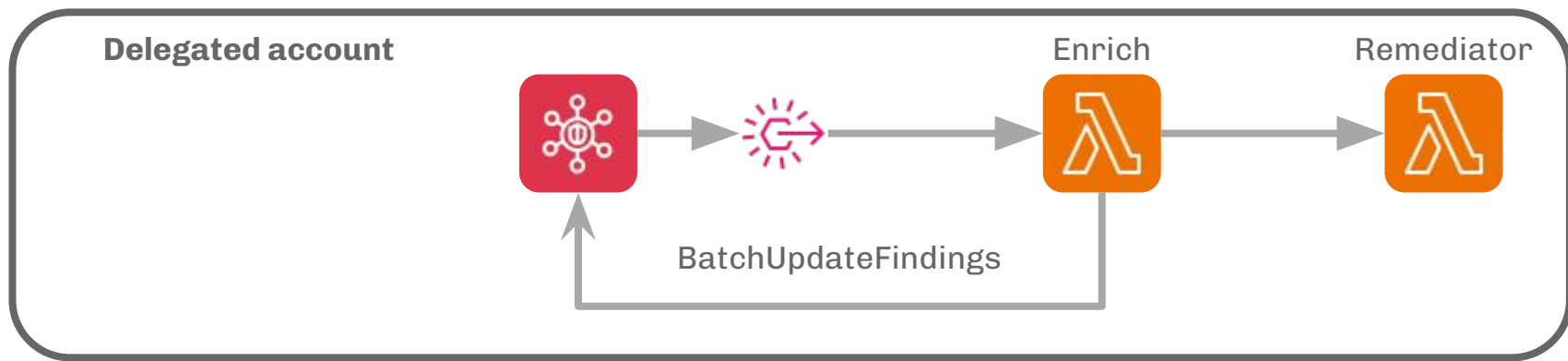
Auto
Remediation



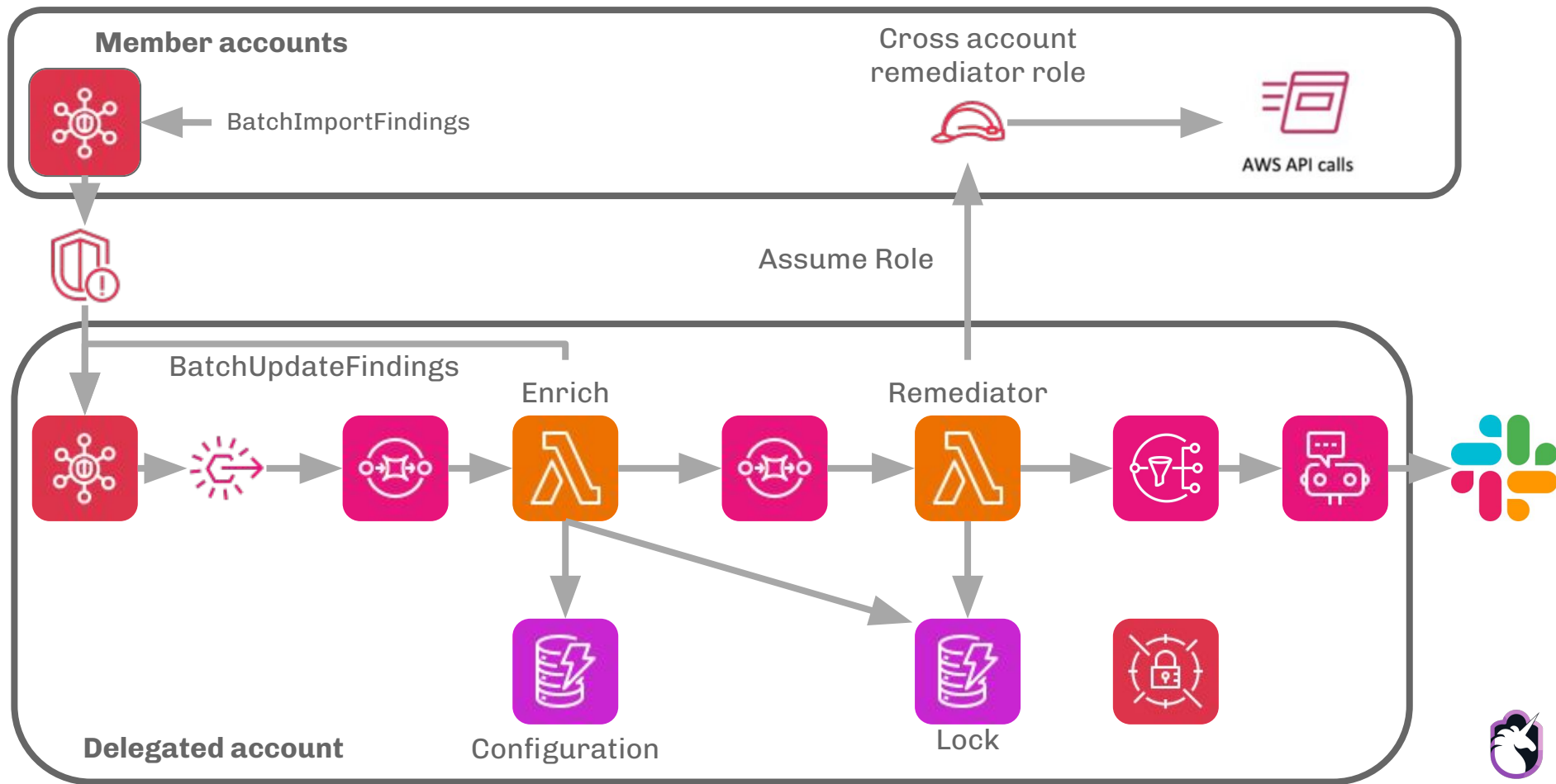
Key Design Decisions

Bypass

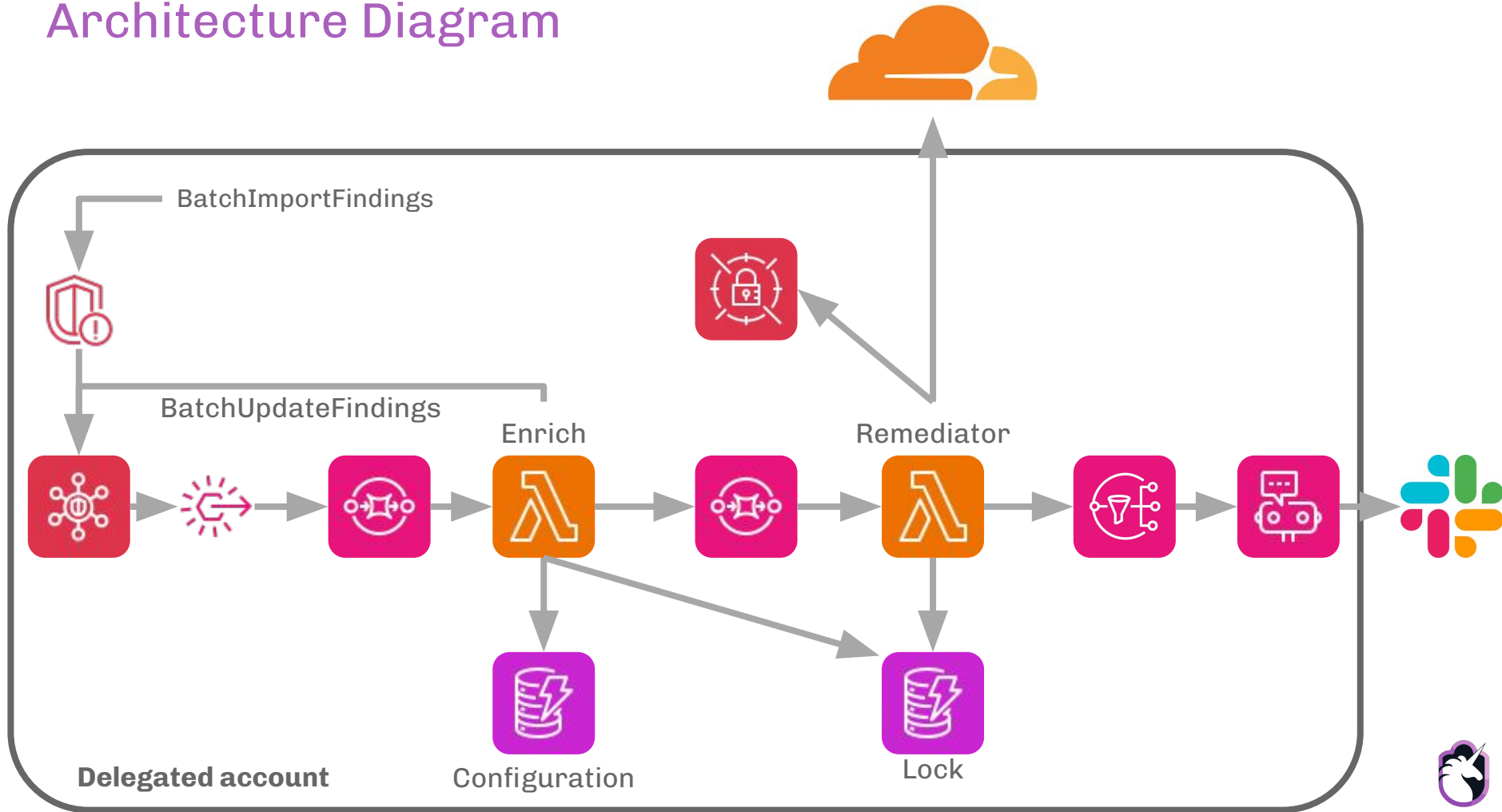
```
for each tag in resource.tags:  
    if tag.key == "disable-remediation" and tag.value == "true":  
        skip remediation
```



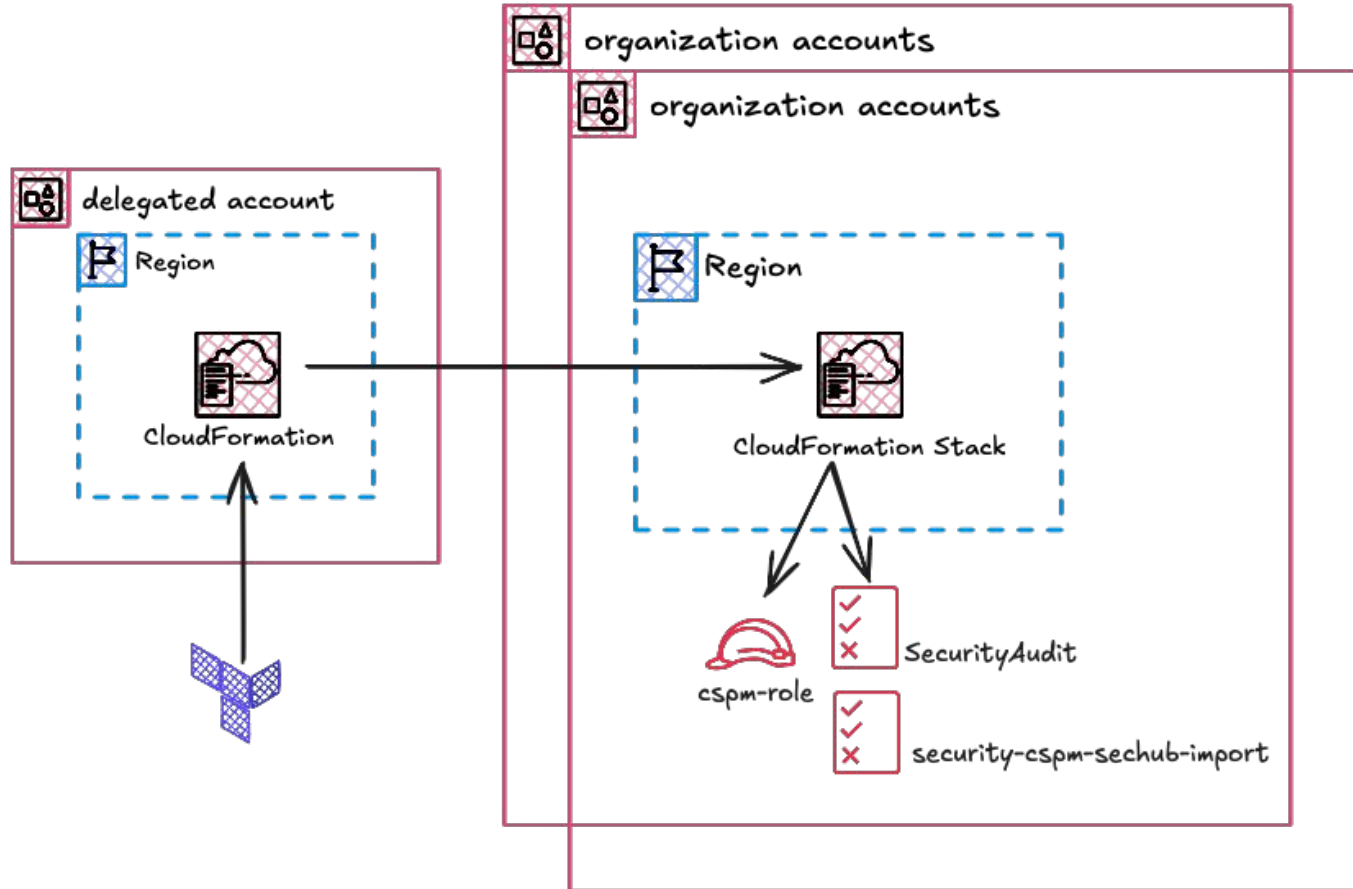
Architecture Diagram



Architecture Diagram



Architecture Diagram



<https://unicrons.cloud/en/2024/10/14/deploy-iam-roles-across-an-aws-organization-as-code/>



Lessons Learned in Production



Lessons Learned in Production

Always track what's happening



Amazon Q APP 8:24 PM

replied to [a thread](#)

✅ **Remediation Executed: aws_s3_bucket_restrict_public_access**

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`

Custom notification delivered by Amazon Q Developer



Amazon Q APP 8:28 PM

replied to [a thread](#)

⏮ **Remediation Skipped: aws_s3_bucket_restrict_public_access**

The following remediation was skipped due to an existing lock:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`

Custom notification delivered by Amazon Q Developer



Lessons Learned in Production

**The bypass method is
~~recommended~~
mandatory**



Lessons Learned in Production

0 production incidents

(at this moment 🙌)



Lessons Learned in Production

Use it for more than just misconfigurations



<https://youtu.be/xIF1bqEPBY8>



SANS

IaC Meets Reality:
Engineering for the Cloud You
Actually Have

Andoni Alonso, Cloud Security Engineer, Prowler
Samuel Burgos, Cloud Security Engineer, Flywire

Summit: Oct 2 - 3 | Training: Oct 4 - 9
Denver, CO & Live Online

CloudSecNext
2025



Lessons Learned in Production

 [Security Hub CSPM](#) > Findings

Security Hub CSPM

Summary

Controls

Security standards

Findings (1/20+)

Actions ▲

Workflow status ▼

Remediate

issue or failed security check and then creating an insight.

```
resource "aws_securityhub_action_target" "example" {  
  depends_on = [aws_securityhub_account.example]  
  name       = "Send notification to chat"  
  identifier = "SendToChat"  
  description = "This is custom action sends selected findings to chat"  
}
```



Lessons Learned in Production

We have saved +5 hours per week



Lessons Learned in Production

**We reduced our response time
from 24h - 7d
to less than 5 minutes**



Lessons Learned in Production

**We reduced the price from
100K/year to 1.5K/year***

**At the same time our infrastructure
doubled in size, and
we expanded our area of operation to
other providers.**



Lessons Learned in Production

**We reduced the price from
100K/year to 1.5K/year***



DEMO



Demo

Remediation Configuration

► Add Configuration

Control	Provider	Enabled	Scope Enabled	Scope Disabled	Exceptions	Actions
aws_ebs_default_encryption_enabled	aws		*			Edit Delete
aws_iam_password_policy	aws		*			Edit Delete
aws_kms_cmk_rotation_enabled	aws		*			Edit Delete
aws_s3_bucket_restrict_public_access	aws		*		arn:aws:s3:::remediator-demo-1	Edit Delete
cf_zones_settings_min_tls_version	cloudflare		*			Edit Delete
cf_zones_settings_replace_insecurejs	cloudflare		*			Edit Delete



Demo

Public Access Block - remediator-demo-1

```
{  
  "BlockPublicAcls": false,  
  "BlockPublicPolicy": false,  
  "IgnorePublicAcls": false,  
  "RestrictPublicBuckets": false  
}
```

Public Access Block - remediator-demo-2

```
{  
  "BlockPublicAcls": false,  
  "BlockPublicPolicy": false,  
  "IgnorePublicAcls": false,  
  "RestrictPublicBuckets": false  
}
```

Public Access Block - remediator-demo-3

```
{  
  "BlockPublicAcls": false,  
  "BlockPublicPolicy": false,  
  "IgnorePublicAcls": false,  
  "RestrictPublicBuckets": false  
}
```



Demo

SecurityHub Finding

Provider: aws
Control: aws_s3_bucket_restrict_public_access
Region: us-west-2
Resource: arn:aws:s3:::remediator-demo-1

Done!

SecurityHub Finding

Provider: aws
Control: aws_s3_bucket_restrict_public_access
Region: us-west-2
Resource: arn:aws:s3:::remediator-demo-2

Done!

SecurityHub Finding

Provider: aws
Control: aws_s3_bucket_restrict_public_access
Region: us-west-2
Resource: arn:aws:s3:::remediator-demo-3

Done!



Demo



Amazon Q APP 8:24 PM

replied to [a thread](#)



Remediation Executed: aws_s3_bucket_restrict_public_access

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`



Custom notification delivered by Amazon Q Developer



Amazon Q APP 8:24 PM

replied to [a thread](#)



Remediation Executed: aws_s3_bucket_restrict_public_access

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-3`



Custom notification delivered by Amazon Q Developer



Demo



Amazon Q APP 8:24 PM

! Security Hub Finding | us-west-2 | Account:

Demo Finding - aws_s3_bucket_restrict_public_access

Demo finding for control aws_s3_bucket_restrict_public_access on resource arn^{aws}
s3::remediator-demo-1

Finding Type: Software and Configuration Checks

Affected Resource

arn^{aws}s3::remediator-demo-1

Severity

High

Suppress finding



Added by Amazon Q Developer



Demo

Remediator Locks

Search by resource identifier or control...

Resource Identifier	Control	TTL	Actions
arn:aws:s3:::remediator-demo-2	aws_s3_bucket_restrict_public_access	2026-06-03 18:24:02 UTC	Delete
arn:aws:s3:::remediator-demo-3	aws_s3_bucket_restrict_public_access	2026-06-03 18:24:09 UTC	Delete



Demo

Public Access Block - remediator-demo-1

```
{
  "BlockPublicAcls": false,
  "BlockPublicPolicy": false,
  "IgnorePublicAcls": false,
  "RestrictPublicBuckets": false
}
```

Public Access Block - remediator-demo-2

```
{
  "BlockPublicAcls": true,
  "BlockPublicPolicy": true,
  "IgnorePublicAcls": true,
  "RestrictPublicBuckets": true
}
```

Public Access Block - remediator-demo-3

```
{
  "BlockPublicAcls": true,
  "BlockPublicPolicy": true,
  "IgnorePublicAcls": true,
  "RestrictPublicBuckets": true
}
```



Demo

Remediation Event

Provider: aws
Control: aws_s3_bucket_restrict_public_access
Region: us-west-2
Resource: arn:aws:s3:::remediator-demo-1



Demo

Public Access Block - remediator-demo-1

```
{  
  "BlockPublicAcls": true,  
  "BlockPublicPolicy": true,  
  "IgnorePublicAcls": true,  
  "RestrictPublicBuckets": true  
}
```



Demo



Remediation Executed: aws_s3_bucket_restrict_public_access

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-1`



Custom notification delivered by Amazon Q Developer



Demo

Remediation Event

Provider: aws

Control: aws_s3_bucket_restrict_public_access

Region: us-west-2

Resource: arn:aws:s3:::remediator-demo-2

Done!



Demo



Amazon Q APP 8:28 PM

replied to [a thread](#)



Remediation Skipped: aws_s3_bucket_restrict_public_access

The following remediation was skipped due to an existing lock:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`



Custom notification delivered by Amazon Q Developer



Demo

Remediator Locks

Search by resource identifier or control...

Resource Identifier	Control	TTL	Actions
arn:aws:s3:::remediator-demo-1	aws_s3_bucket_restrict_public_access	2026-06-03 18:27:16 UTC	Delete
arn:aws:s3:::remediator-demo-2	aws_s3_bucket_restrict_public_access	2026-06-03 18:24:02 UTC	Delete
arn:aws:s3:::remediator-demo-3	aws_s3_bucket_restrict_public_access	2026-06-03 18:24:09 UTC	Delete



Where to start? Our first steps...



“Safe” changes

- Password Policy
- Delete Root Access Keys
- Enable Security Services
- Enable KMS Rotation

Potential Impact Changes

- Public AMI / EBS
- EBS Default Encryption
- Public Buckets
- Public Security Groups



Thanks for coming!



sbldvnet



samuelburgos



andoniaf



andoniaf.unicrons.cloud



unicrons



@unicrons_cloud



unicrons.cloud



Questions?



Aitäh!

